

Information Security Policy

CT Committee Treasurer Suite

Effective date: July 11, 2026

Last reviewed: July 11, 2026

Policy owner: Todd Fanciullo (Founder / Operator)

Contact: support@cttreasurer.com

1. Purpose and Scope

This policy defines how CT Committee Treasurer Suite ("the Service") protects the confidentiality, integrity, and availability of customer data. It applies to the production application at <https://ct-treasurer.vercel.app>, its source code, supporting infrastructure, and all personnel with access to production systems or customer data.

The Service is a software-as-a-service application that helps Connecticut political committees track contributions and expenditures, reconcile bank activity, and prepare SEEC campaign-finance filings.

2. Roles and Responsibilities

The Service is operated by its founder, who acts as security owner and is responsible for implementing this policy, managing production access, reviewing third-party providers, and leading incident response. Any future personnel or contractors will be granted access on a least-privilege basis and will be bound by this policy before receiving access to production systems or customer data.

3. Data Classification

Class	Examples	Handling
Restricted	API secrets and signing keys; database credentials; encrypted committee email credentials; Plaid access tokens	Stored only in environment-variable stores or encrypted at the application layer; never in source control, logs, or client responses
Confidential	Donor names, addresses, employers, occupations; contribution and expenditure records; bank account transaction data; committee member emails	Encrypted in transit and at rest; access restricted by authentication, role, and committee membership
Internal	Application source code, configuration	Private repository; access limited to authorized personnel
Public	Marketing pages, published documentation	No restrictions

The Service deliberately minimizes sensitive data it holds:

- **No bank credentials.** Bank connections use Plaid Link; users authenticate directly with their institution and the Service receives only a scoped access token and read-only transaction data.
- **No payment card data.** Billing is processed by Stripe Checkout; card numbers never touch the Service's infrastructure.
- **No government identifiers.** The Service does not collect Social Security numbers or driver's license numbers.

4. Access Control

- **Customer access** is authenticated through Supabase Auth. Committee access is invitation-only or self-serve signup; every authenticated request is scoped to committees where the user holds a membership, enforced server-side on every page and mutation.
- **Role-based authorization:** financial mutations (contributions, expenditures, bank linking and sync, filings) are restricted to Treasurer and Assistant Treasurer roles and enforced in server-side code, not merely hidden in the UI. All other roles are read-only.
- **Tenant isolation:** the application is multi-tenant; every financial record carries a committee identifier, all queries are scoped to it, and PostgreSQL row-level security (RLS) is enabled on the database as defense in depth.
- **Administrative access** to production infrastructure (Vercel, Supabase, Stripe, Plaid dashboards) is limited to the policy owner and protected by the providers' account security controls.
- Sessions are managed by Supabase Auth with automatic refresh; session cookies are set with the `Secure` flag and unauthenticated requests to application routes are redirected to login by edge middleware.

5. Encryption and Secrets Management

- **In transit:** all traffic is served exclusively over TLS (HTTPS). HTTP Strict Transport Security is enforced with a two-year max-age including subdomains.
- **At rest:** the production PostgreSQL database (Supabase) encrypts data at rest with AES-256. Long-lived third-party credentials stored by the application (committee email app passwords) receive an additional layer of application-level encryption using AES-256-GCM with a dedicated key held only in the production environment store; these values are never returned to clients or written to logs in plaintext.
- **Secrets:** API keys, database URLs, webhook signing secrets, and encryption keys are stored in Vercel's encrypted environment-variable store and local `.env` files excluded from source control. Secrets are never committed to the repository. Production and development use entirely separate databases, auth pools, and credentials.

6. Application and Development Security

- All database access goes through a typed ORM (Prisma) with parameterized queries, precluding SQL injection.

- Inbound webhooks are cryptographically verified before processing: Stripe webhooks via Stripe signature verification, Anedot webhooks via HMAC-SHA256 signatures.
- Server Actions restrict allowed origins; baseline security headers are applied to every response, including `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY` with a `frame-ancestors 'none'` CSP directive (clickjacking protection), `Referrer-Policy: strict-origin-when-cross-origin`, and a restrictive `Permissions-Policy`.
- Authorization checks are performed server-side on every mutation; ownership of cross-tenant records (e.g., shared contributor profiles) is verified before writes.
- The codebase is TypeScript with static analysis (ESLint) and an automated unit-test suite covering compliance-critical logic; type checks, lint, and tests run in continuous integration before changes ship.
- Dependencies are monitored and updated regularly; security patches to the framework and libraries are prioritized.

7. Infrastructure and Third-Party Providers

The Service runs entirely on managed infrastructure — there are no self-managed servers to patch. Subprocessors:

Provider	Function	Security posture
Vercel	Application hosting, TLS termination, DDoS mitigation	SOC 2 Type II, ISO 27001
Supabase	Authentication, PostgreSQL database	SOC 2 Type II, HIPAA-capable
Stripe	Subscription billing	PCI DSS Level 1, SOC 2
Plaid	Bank account connectivity (read-only transactions)	SOC 2 Type II, ISO 27001
Anedot	Inbound donation data (webhooks/CSV)	SOC 2
Google (Gmail SMTP)	Outbound committee newsletters, at each committee's election using its own account	SOC 2, ISO 27001

Providers are reviewed before adoption for security certifications and data-handling terms, and the list above is reviewed at least annually.

8. Backup and Availability

Production data is backed up through Supabase's automated backups. Application deployments are immutable and versioned on Vercel, allowing rapid rollback of a bad release. The database and the application are hosted on independent providers, so a compromise or outage of one does not directly expose the other.

9. Logging and Monitoring

Application and function logs are collected by the hosting platform. Logs exclude secrets and plaintext credentials. Webhook processing is idempotent and failures are logged for review. Anomalies in billing, authentication, or bank-sync behavior are investigated when detected.

10. Incident Response

Upon discovery of a suspected security incident (unauthorized access, data exposure, credential compromise):

1. **Contain** — revoke or rotate affected credentials (all provider keys and the application encryption key can be rotated without data loss, excepting re-encryption of stored credentials), disable affected accounts, and take affected functionality offline if necessary.
2. **Assess** — determine scope, affected committees, and data categories involved, using provider logs.
3. **Notify** — affected customers will be notified without undue delay and no later than 72 hours after confirmation of a breach involving their data, with a description of what occurred and remediation steps.
4. **Remediate and review** — fix the root cause, document the incident, and update this policy or controls as warranted.

Security reports from customers or researchers may be sent to support@cttreasurer.com and will be acknowledged promptly. Good-faith security research is welcome; we ask reporters to avoid accessing other users' data and to allow reasonable time for remediation before disclosure.

11. Data Retention and Deletion

Customer data is retained while an account is active. Upon account termination, data is retained for 30 days (allowing recovery from accidental cancellation) and then permanently deleted, consistent with the Terms of Service. Customers may request earlier deletion by contacting support. Plaid access tokens are invalidated when a bank connection is removed.

12. Acceptable Use and Personnel

Anyone with production access must: use unique, strong credentials and enable multi-factor authentication on provider accounts where available; access customer data only as required to operate and support the Service; never store customer data on unmanaged personal devices; and report suspected incidents immediately.

13. Policy Review

This policy is reviewed and updated at least annually, and additionally after any material change to architecture, subprocessors, or applicable requirements. The effective and last-reviewed dates at the top of this document reflect the current revision.